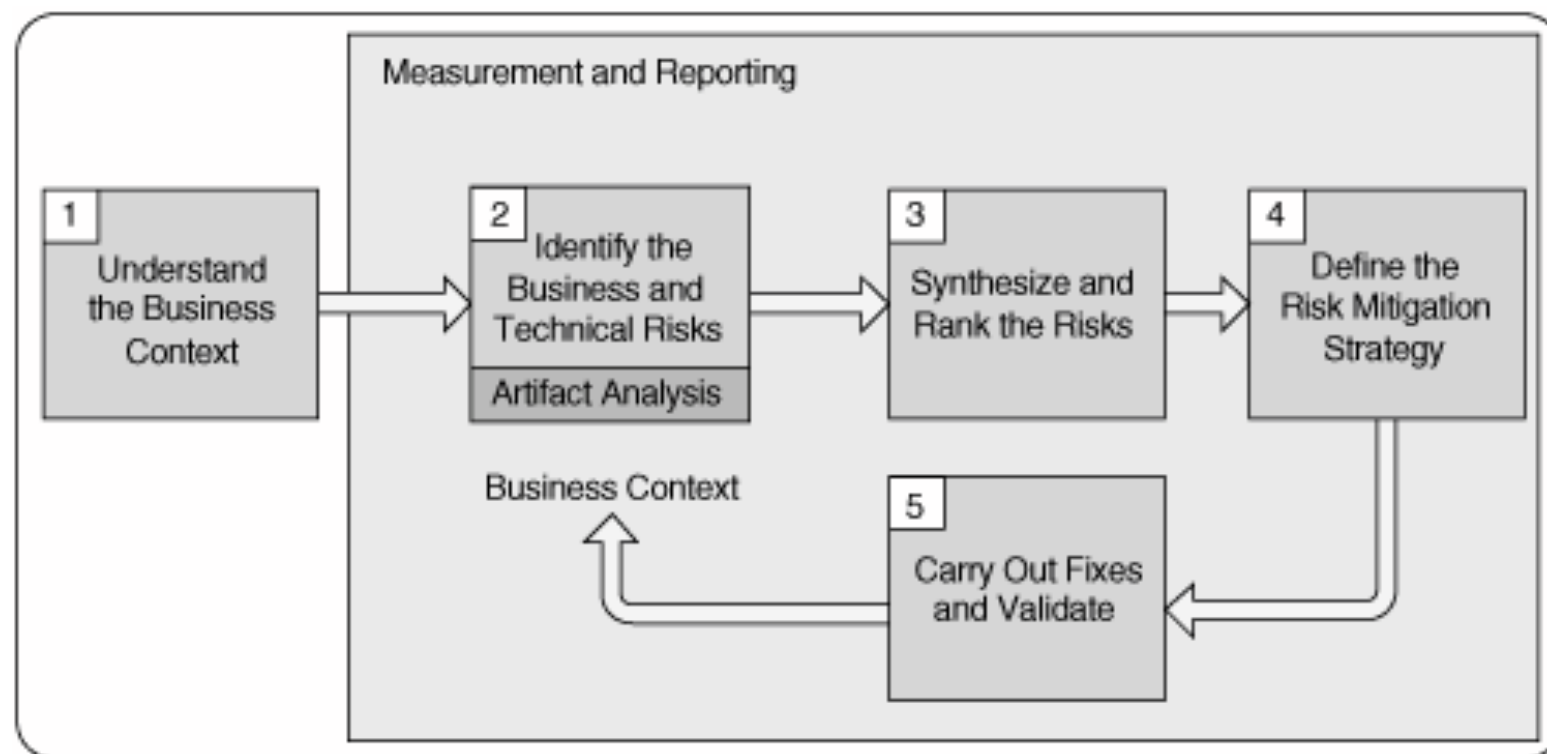


Secure Software Design and Development (CY-321)

Risk Management for Software (2)



Risk Management

Understanding the Business Context

- *Gathering the Artifacts*
- *Conducting Project Research*

Identifying the Business and Technical Risks

- *Developing Risk Questionnaires*
- *Interviewing the Target Project Team*
- *Analyzing the Research and Interview Data*



KillerAppCo has launched **iWare 1.0**, a web-based software for managing user accounts, payments, and confidential business data. The iWare server runs on Linux, is accessible over the internet, and stores sensitive user information including emails, passwords, and payment details.

Rank	Business Goal	Description
H These goals are critical to the existence of the project	<u>TIME TO MARKET</u> iWare 1.0 Server must be released on January 1, 2008.	KillerAppCo desires to release iWare 1.0 on January 1, 2008, to achieve first-to-market status, which will enable KillerAppCo to secure 25% of the market prior to competitor entry.
M A failure to achieve a medium-rank business goal may result in a negative affect to high-rank goals	<u>AVAILABILITY</u> iWare 1.0 Server must provide 99.999% uptime.	A large share of the iWare 1.0 Server market consists of Fortune 500 companies with whom KillerAppCo will have SLAs. The server's availability is a critical factor in enabling KillerAppCo to meet the SLA requirements.
M	<u>ACCURACY</u> Transactions must be recorded with 100% accuracy, with no invalid, duplicate, or missing transactions.	Federal regulations stipulate that iWare 1.0 Server must perform all financial transactions with 100% accuracy.

Low (L) These goals affect only a small portion of the company's revenue. A small number of employees may be affected if these goals are not met.

Business Risk	Description
The software fails to meet the acceptance criteria required for release. <u>TIME TO MARKET</u>	The software may fail user acceptance testing criteria. Such failure will affect the release date, negatively affecting the time to market and possibly the company's brand and reputation. The share price of a publicly owned company may be negatively impacted.
System failures cause unplanned downtime. <u>AVAILABILITY</u>	Any unplanned downtime caused by system failures negatively affects the revenue from the project. In case of the existence of an SLA, this may cause direct monetary loss for the company. Unplanned downtime requires additional resources to execute disaster recovery plans and, possibly, to manually process the data usually processed by the system. News about the unplanned downtime may damage users' perceptions about the system and negatively affect users' demand for the system's services.

Business Risk	Description	Business Risk Indicators	Likelihood of Occurrence
The software fails to meet the acceptance criteria required for release. <u>TIME TO MARKET</u>	The software may fail user acceptance testing criteria. Such failure will affect the release date, negatively affecting the time to market and possibly the company's brand and reputation. The share price of a publicly owned company may be negatively impacted.	1. Number of missed project milestones 2. Number of critical-level errors	H The threat is highly motivated and sufficiently capable, and controls to prevent the risk from occurring are ineffective.
System failures cause unplanned downtime. <u>AVAILABILITY</u>	Any unplanned downtime caused by system failures negatively affects the revenue from the project. In case of the existence of an SLA, this may cause direct monetary loss for the company. Unplanned downtime requires additional resources to execute disaster recovery plans and, possibly, to manually process the data usually processed by the system. News about the unplanned downtime may damage users' perceptions about the system and negatively affect users' demand for the system's services.	1. Number of incorrect critical operations performed 2. Effort required to perform the same business functions using alternative routes	M The threat is motivated and capable, but controls are in place that may impede successful materialization of the risk.

Business Risk	Business Risk Indicators	Likelihood of Occurrence	Impact	Estimated Cost
The software fails to meet the acceptance criteria required for release. <u>TIME TO MARKET</u>	1. Number of missed project milestones 2. Number of critical-level errors	H The threat is highly motivated and sufficiently capable, and controls to prevent the risk from occurring are ineffective.	KillerAppCo will be unable to release the product to the market. H	Revenue loss: <u>\$10 million</u> Market share loss: <u>15%</u> Brand and reputation damage: limited
System failures cause unplanned downtime. <u>AVAILABILITY</u>	1. Number of incorrect critical operations performed 2. Effort required to perform the same business functions using alternative routes	M The threat is motivated and capable, but controls are in place that may impede successful materialization of the risk.	KillerAppCo will be unable to meet its clients' SLA availability requirements. M	Revenue loss: <u>\$3 million</u> Market share loss: <u>5%</u> Brand and reputation damage: extreme

Business Impact Value	Definition
High (H)	(1) Very costly loss of major tangible assets or resources; (2) significant violation of, or harm or impediment to, an organization's mission, reputation, or interest; or (3) human death or serious injury.
Medium (M)	(1) Costly loss of tangible assets or resources; (2) violation of, or harm or impediment to, an organization's mission, reputation, or interest; or (3) human injury.
Low (L)	(1) Loss of some tangible assets or resources; or (2) a noticeable effect on an organization's mission, reputation, or interest.

Risk Severity



Likelihood	Impact			
		L	M	H
	H	L	M	H
	M	L	M	M
	L	L	L	L

Business Risk	Business Risk Indicators	Likelihood of Occurrence	Impact	Estimated Cost
The software fails to meet the acceptance criteria required for release. <u>TIME TO MARKET</u>	1. Number of missed project milestones 2. Number of critical-level errors	H The threat is highly motivated and sufficiently capable, and controls to prevent the risk from occurring are ineffective.	KillerAppCo will be unable to release the product to the market. H	Revenue loss: <u>\$10 million</u> Market share loss: <u>15%</u> Brand and reputation damage: limited
System failures cause unplanned downtime. <u>AVAILABILITY</u>	1. Number of incorrect critical operations performed 2. Effort required to perform the same business functions using alternative routes	M The threat is motivated and capable, but controls are in place that may impede successful materialization of the risk.	KillerAppCo will be unable to meet its clients' SLA availability requirements. M	Revenue loss: <u>\$3 million</u> Market share loss: <u>5%</u> Brand and reputation damage: extreme

KillerAppCo's Technical Risks

ID	Technical Risk
TR1	Developers do not have access to quality assurance (QA) tools for unit testing.
TR2	QA tests do not fully evaluate requirements.
TR3	A. Testing does not cover fault tolerance. System failures are likely. B. Testing does not cover fault tolerance. Hardware failures can create incorrect transactions.
TR4	System is susceptible to denial-of-service attacks.
TR5	A. Poor random number generation (RNG) makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor RNG makes crypto weak. Attackers can influence transactions or create illegitimate transactions.
TR6	Poor enforcement of access control rules allows misuse by insiders and outsiders.



Technical Risk Indicators

ID #



ID #	Technical Risk
------	----------------



ID #	Technical Risk	Technical Risk Indicators
------	----------------	---------------------------



ID #	Technical Risk	Technical Risk Indicators	Likelihood
------	----------------	---------------------------	------------



ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1			



ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.		



ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	



ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H



ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2			



ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .		



ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	



ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H



ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3			

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance. System failures are likely. B. Testing does not cover fault tolerance. Hardware failures can create incorrect transactions.		

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance. System failures are likely. B. Testing does not cover fault tolerance. Hardware failures can create incorrect transactions.	Number of faults reported Number of inaccurate transactions	

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance. System failures are likely. B. Testing does not cover fault tolerance. Hardware failures can create incorrect transactions.	Number of faults reported Number of inaccurate transactions	H

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance. System failures are likely. B. Testing does not cover fault tolerance. Hardware failures can create incorrect transactions.	Number of faults reported Number of inaccurate transactions	H
TR4			

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance . System failures are likely. B. Testing does not cover fault tolerance . Hardware failures can create incorrect transactions .	Number of faults reported Number of inaccurate transactions	H
TR4	System is susceptible to denial-of-service attacks.		

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance . System failures are likely. B. Testing does not cover fault tolerance . Hardware failures can create incorrect transactions .	Number of faults reported Number of inaccurate transactions	H
TR4	System is susceptible to denial-of-service attacks.	Number of unauthorized logins Mean server availability	

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance . System failures are likely. B. Testing does not cover fault tolerance . Hardware failures can create incorrect transactions .	Number of faults reported Number of inaccurate transactions	H
TR4	System is susceptible to denial-of-service attacks.	Number of unauthorized logins Mean server availability	H

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance . System failures are likely. B. Testing does not cover fault tolerance . Hardware failures can create incorrect transactions .	Number of faults reported Number of inaccurate transactions	H
TR4	System is susceptible to denial-of-service attacks.	Number of unauthorized logins Mean server availability	H
TR5			

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance . System failures are likely. B. Testing does not cover fault tolerance . Hardware failures can create incorrect transactions .	Number of faults reported Number of inaccurate transactions	H
TR4	System is susceptible to denial-of-service attacks.	Number of unauthorized logins Mean server availability	H
TR5	A. Poor RNG makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor RNG makes crypto weak. Attackers can influence transactions or create illegitimate transactions .		

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance . System failures are likely. B. Testing does not cover fault tolerance . Hardware failures can create incorrect transactions .	Number of faults reported Number of inaccurate transactions	H
TR4	System is susceptible to denial-of-service attacks.	Number of unauthorized logins Mean server availability	H
TR5	A. Poor RNG makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor RNG makes crypto weak. Attackers can influence transactions or create illegitimate transactions .	Number of unauthorized logins Number of unauthorized accesses Number of inaccurate transactions Number of IDS anomalies	

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance . System failures are likely. B. Testing does not cover fault tolerance . Hardware failures can create incorrect transactions .	Number of faults reported Number of inaccurate transactions	H
TR4	System is susceptible to denial-of-service attacks.	Number of unauthorized logins Mean server availability	H
TR5	A. Poor RNG makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor RNG makes crypto weak. Attackers can influence transactions or create illegitimate transactions .	Number of unauthorized logins Number of unauthorized accesses Number of inaccurate transactions Number of IDS anomalies	H

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance . System failures are likely. B. Testing does not cover fault tolerance . Hardware failures can create incorrect transactions .	Number of faults reported Number of inaccurate transactions	H
TR4	System is susceptible to denial-of-service attacks.	Number of unauthorized logins Mean server availability	H
TR5	A. Poor RNG makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor RNG makes crypto weak. Attackers can influence transactions or create illegitimate transactions .	Number of unauthorized logins Number of unauthorized accesses Number of inaccurate transactions Number of IDS anomalies	H
TR6			

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance . System failures are likely. B. Testing does not cover fault tolerance . Hardware failures can create incorrect transactions .	Number of faults reported Number of inaccurate transactions	H
TR4	System is susceptible to denial-of-service attacks.	Number of unauthorized logins Mean server availability	H
TR5	A. Poor RNG makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor RNG makes crypto weak. Attackers can influence transactions or create illegitimate transactions .	Number of unauthorized logins Number of unauthorized accesses Number of inaccurate transactions Number of IDS anomalies	H
TR6	Poor enforcement of access control rules allows misuse by insiders and outsiders.		

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance . System failures are likely. B. Testing does not cover fault tolerance . Hardware failures can create incorrect transactions .	Number of faults reported Number of inaccurate transactions	H
TR4	System is susceptible to denial-of-service attacks.	Number of unauthorized logins Mean server availability	H
TR5	A. Poor RNG makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor RNG makes crypto weak. Attackers can influence transactions or create illegitimate transactions .	Number of unauthorized logins Number of unauthorized accesses Number of inaccurate transactions Number of IDS anomalies	H
TR6	Poor enforcement of access control rules allows misuse by insiders and outsiders.	Number of unauthorized accesses	

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H
TR3	A. Testing does not cover fault tolerance . System failures are likely.	Number of faults reported	H
	B. Testing does not cover fault tolerance . Hardware failures can create incorrect transactions .	Number of inaccurate transactions	
TR4	System is susceptible to denial-of-service attacks.	Number of unauthorized logins Mean server availability	H
TR5	A. Poor RNG makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor RNG makes crypto weak. Attackers can influence transactions or create illegitimate transactions .	Number of unauthorized logins Number of unauthorized accesses Number of inaccurate transactions Number of IDS anomalies	H
TR6	Poor enforcement of access control rules allows misuse by insiders and outsiders.	Number of unauthorized accesses	H

ID #	Technical Risk	Technical Risk Indicators	Likelihood	Impact
TR1	Developers do not have access to QA tools for unit testing.	Number of development-phase bugs reported	H	The inaccessibility of QA tools for developers to use in unit testing may lead to QA problems and acceptance criteria failures.
TR2	QA tests do not fully evaluate requirements .	Number of requirements-phase bugs reported post-implementation	H	The partial evaluation of requirements by QA tests may lead to QA problems and acceptance criteria failures.
TR3	A. Testing does not cover fault tolerance . System failures are likely. B. Testing does not cover fault tolerance . Hardware failures can create incorrect transactions .	Number of faults reported Number of inaccurate transactions	H	Lack of fault tolerance test coverage may lead to unplanned downtime and inaccurate critical operations.
TR4	System is susceptible to denial-of-service attacks.	Number of unauthorized logins Mean server availability	H	DoS susceptibility may lead to unplanned downtime.
TR5	A. Poor RNG makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor RNG makes crypto weak. Attackers can influence transactions or create illegitimate transactions .	Number of unauthorized logins Number of unauthorized accesses Number of inaccurate transactions Number of IDS anomalies	H	Poor RNG implementation may lead to system failures, unexplained behavior, and inaccurate transactions.
TR6	Poor enforcement of access control rules allows misuse by insiders and outsiders.	Number of unauthorized accesses	H	Poor access rule enforcement may lead to unexplained behavior and system failures.

Synthesizing and Ranking the Risks

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.			

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.		

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.
		TR2	

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.
		TR2	QA tests do not fully evaluate requirements.

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.
		TR2	QA tests do not fully evaluate requirements.
AVAILABILITY iWare 1.0 Server must provide 99.999% uptime.			

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.
		TR2	QA tests do not fully evaluate requirements.
AVAILABILITY iWare 1.0 Server must provide 99.999% uptime.	System failures cause unplanned downtime.		

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.
		TR2	QA tests do not fully evaluate requirements.
AVAILABILITY iWare 1.0 Server must provide 99.999% uptime.	System failures cause unplanned downtime.	TR3	

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.
		TR2	QA tests do not fully evaluate requirements.
AVAILABILITY iWare 1.0 Server must provide 99.999% uptime.	System failures cause unplanned downtime.	TR3	A. Testing does not cover fault tolerance. System failures are likely.

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.
		TR2	QA tests do not fully evaluate requirements.
AVAILABILITY iWare 1.0 Server must provide 99.999% uptime.	System failures cause unplanned downtime.	TR3	A. Testing does not cover fault tolerance. System failures are likely.
		TR4	

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.
		TR2	QA tests do not fully evaluate requirements.
AVAILABILITY iWare 1.0 Server must provide 99.999% uptime.	System failures cause unplanned downtime.	TR3	A. Testing does not cover fault tolerance. System failures are likely.
		TR4	System is susceptible to denial-of-service attacks.

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.
		TR2	QA tests do not fully evaluate requirements.
AVAILABILITY iWare 1.0 Server must provide 99.999% uptime.	System failures cause unplanned downtime.	TR3	A. Testing does not cover fault tolerance. System failures are likely.
		TR4	System is susceptible to denial-of-service attacks.
	Security weaknesses cause system failures.		

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.
		TR2	QA tests do not fully evaluate requirements.
AVAILABILITY iWare 1.0 Server must provide 99.999% uptime.	System failures cause unplanned downtime.	TR3	A. Testing does not cover fault tolerance. System failures are likely.
		TR4	System is susceptible to denial-of-service attacks.
	Security weaknesses cause system failures.	TR8	

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.
		TR2	QA tests do not fully evaluate requirements.
AVAILABILITY iWare 1.0 Server must provide 99.999% uptime.	System failures cause unplanned downtime.	TR3	A. Testing does not cover fault tolerance. System failures are likely.
		TR4	System is susceptible to denial-of-service attacks.
	Security weaknesses cause system failures.	TR8	System does not require good passwords. Attackers can get in more easily and cause unpredictable behavior.

Technical Risk Severity by Business Goal

ID	Technical Risk	Time to Market (H)	Availability (M)
TR1	Developers do not have access to QA tools for unit testing.	H	N/A
TR2	QA tests do not fully evaluate requirements.	H	N/A
TR3	A. Testing does not cover fault tolerance. System failures are likely. B. Testing does not cover fault tolerance. Hardware failures can create incorrect transactions.	N/A	H
TR4	System is susceptible to denial-of-service attacks.	N/A	H
TR5	A. Poor RNG makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor RNG makes crypto weak. Attackers can influence transactions or create illegitimate transactions.	N/A	H
TR6	Poor enforcement of access control rules allows misuse by insiders and outsiders.	N/A	H

Reviewing the Risk Data

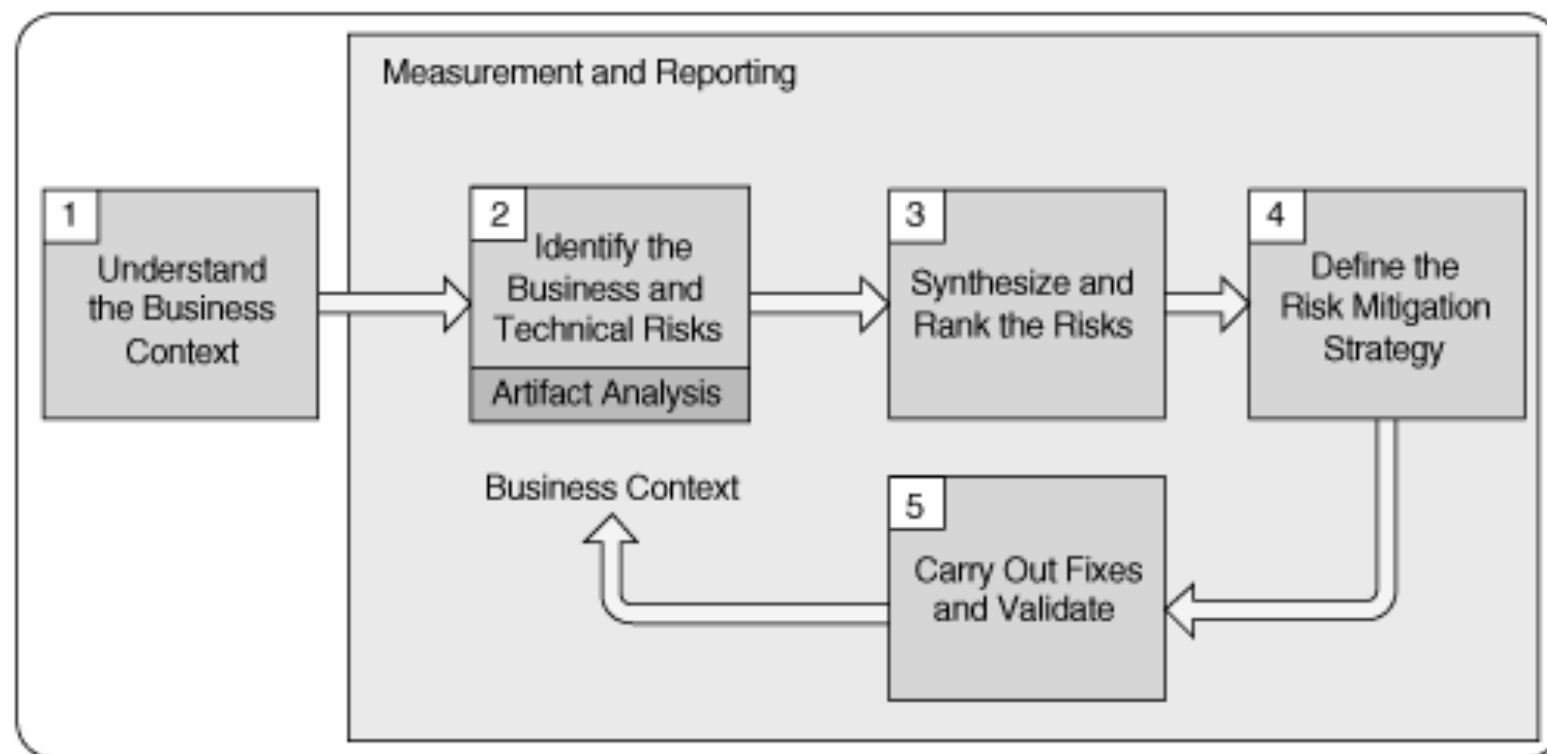
- Confirm the accuracy and comprehensiveness of the business and technical risks
- Confirm the risk likelihood, impact, and severity rankings
- Confirm the relationships between business goals, business risks, and technical risks
- Create a preliminary outline of the risk analysis report, which includes strategic risk mitigation content
- Conducting the Business and Technical Peer Review

Defining the Risk Mitigation Strategy

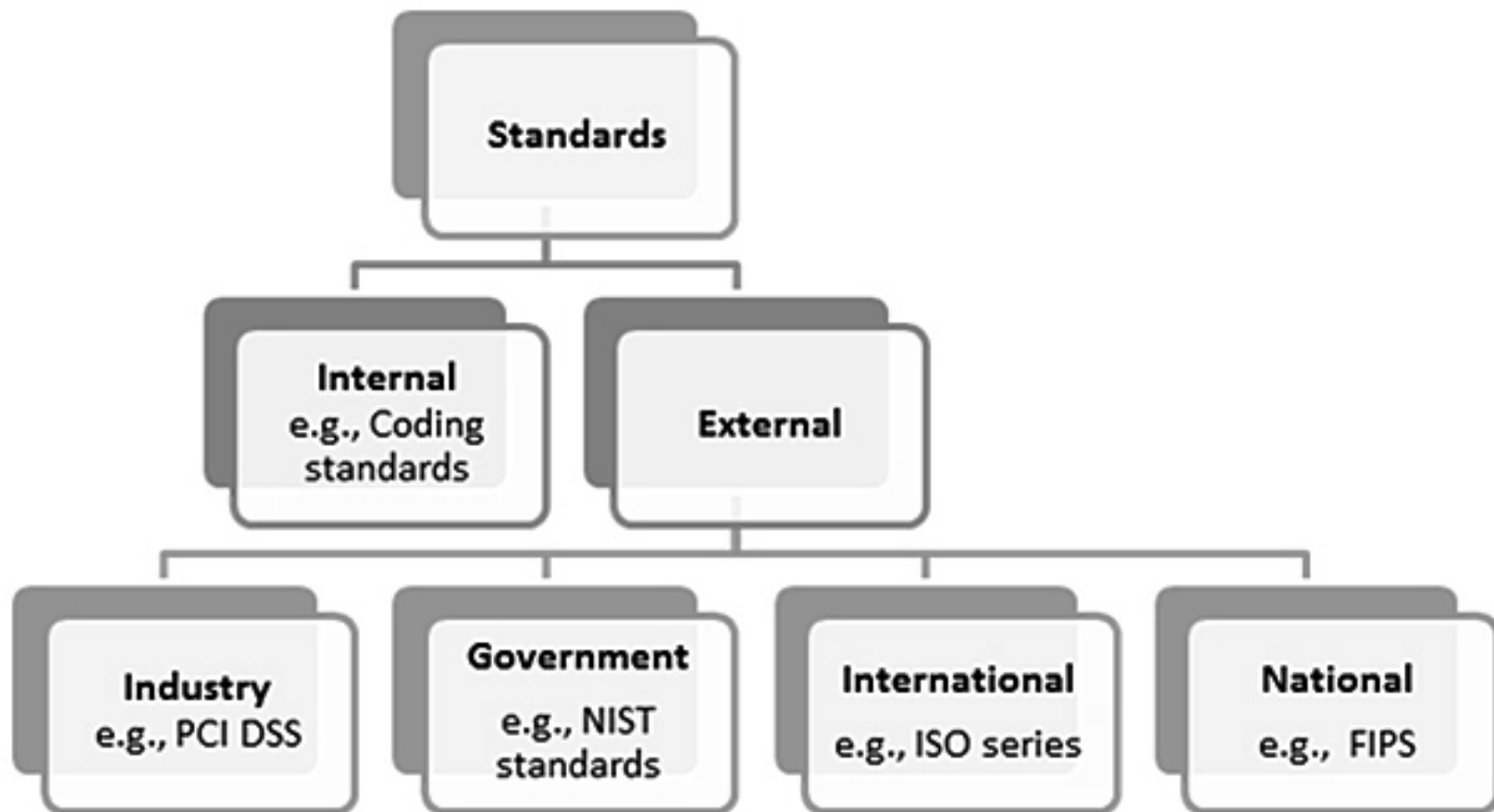
Business Risk	Supporting Technical Risk	Risk Mitigation Method		
		Improve QA in Early SDLC Phases	Add Fault Tolerance to QA Tests	Add Security Requirements and Security Requirements Testing to SDLC
The software fails to meet the acceptance criteria required for release. (H)	TR1	H		
	TR2	H		M
System failures cause unplanned downtime. (M)	TR3	M	H	
	TR4		M	
Security weaknesses cause system failures. (M)	TR5			H
	TR6			H
	TR8			H
The software fails to perform critical operational functions correctly. (M)	TR3	M	H	
	TR5			H
	TR7			H

Carrying Out Fixes and Validating

- Execution of the risk mitigation strategy
- The validation plan is a test plan



Security Standards



Questions??

zubair.ahmad@giki.edu.pk

Office: G14 FCSE lobby